

Information Security Management System for GreenGrid Energy

Master's in Computer Engineering - Cybersecurity and Systems
Administration
Security Management Systems (SIGSEG)

ISEP INSTITUTO SUPERIOR
DE ENGENHARIA DO PORTO

Students:

1200720@isep.ipp.pt

1201346@isep.ipp.pt

1200920@isep.ipp.pt

Contents

1	GreenGrid Energy: Organizational Overview	1
1.1	Introduction	1
1.1.1	Project Team Structure and Individual Responsibilities	1
1.1.2	Collective Responsibilities	2
1.1.3	Forward-Looking Objectives	2
1.2	Governance and Leadership	3
1.3	Key Departments	4
1.3.1	Engineering & Grid Operations	4
1.3.2	Research & Development Department	5
1.3.3	Customer Services & Billing	6
1.3.4	Supply Chain Management Department	7
1.3.5	Human Resources (HR)	8
1.3.6	Legal & Administration	8
1.4	Infrastructure and Security Context	8
1.4.1	Core Technologies and Systems	8
1.4.2	Network Topology	9
1.4.3	Threat Landscape	9
1.4.4	Technology and Department Association	9
2	ISMS Scope	10
2.1	Organizational Stakeholders	10
2.2	Shared IT Infrastructure and Systems	11
2.3	Business Processes, Data, and Security Risks by Department	11
2.3.1	Engineering & Operations	11
2.3.2	Research & Development (R&D)	12
2.3.3	Customer Services	15
2.3.4	Finance	15
2.3.5	Supply Chain Management	16
2.3.6	Human Resources	17
2.3.7	IT Department	17
2.3.8	Sales and Marketing	18
2.4	ISMS Boundaries and Exclusions	18
3	Information Security Policy and Objectives	19
3.1	Stakeholder Requirements and Business Goals	19
3.2	Leadership Commitment	20
3.3	Monitoring and Review of ISMS Performance	20
3.4	Risk Management Goals and Compliance Requirements	20
3.5	Information Security Policy (Clause 4.2)	21

3.6	Department-Specific Security Objectives (Clause 6.2)	21
3.6.1	Engineering & Operations	21
3.6.2	Supply Chain Management	22
3.6.3	Customer Services & Billing	23
3.6.4	Research & Development (Research & Development (RD))	24
4	Other Policies and Procedures	25
4.1	Other Security Policies	25
4.1.1	RD Intellectual Property and Data Security Policy	25
4.1.2	Operational Technology (OT) & Infrastructure Security Policy	26
4.2	Other Security Procedures	27
4.2.1	Procedure 1: Secure Code Review	27
4.2.2	Procedure 2: Access Management for R&D Systems	27
4.2.3	Procedure 3: Incident Management within R&D	27
4.2.4	Procedure 4: Vendor and Partner Security Assessment	28
4.2.5	Procedure 5: Incident Management within OT & Cloud Systems	28

List of Figures

1.1	Organizational chart of GreenGrid Energy	3
1.2	Organizational chart of Supply Chain Management Department	8

Acronyms

APTs	Advanced Persistent Threats
AWS	Amazon Web Services
CEO	Chief Executive Officer
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
ICS	Incident Command System
COO	Chief Operating Officer
CIS	Center for Internet Security
CTO	Chief Technology Officer
DER	Distributed Energy Resources
ERP	Enterprise Resource Planning
HR	Human Resources
ISMS	Information Security Management System
IT	Information Technology
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IoT	Internet of Things
NIST	National Institute of Standards and Technology
OT	Operational Technology
PII	Personally Identifiable Information
RD	Research & Development
SCADA	Supervisory Control and Data Acquisition

CRM	Customer Relationship Management
LAN	Local Area Network
OT	Operational Technology
VPN	Virtual Private Network
AD	Active Directory
MFA	Multi-factor Authentication
RFPs	Requests For Proposals
RFQs	Requests For Quotes
SLA	Service-Level Agreement
MSAs	Master Service Agreements
SOWs	Statements Of Work
SOC	Security Operations Center
SIEM	Security Information and Event Management
EU	European Union

Chapter 1

GreenGrid Energy: Organizational Overview

1.1 Introduction

GreenGrid Energy is a large-scale enterprise³ specialized in renewable energy, with particular expertise in smart grid technology. The company employs approximately 400 professionals and has achieved revenues of around 35 million euros in the latest fiscal year. Its business activities are structured around three core revenue streams:

1. Smart grid infrastructure deployment (45%),
2. Renewable energy supply contracts (40%),
3. Energy monitoring and analytics software (15%).

With the expanding adoption of renewable energy solutions and increasing integration of Internet of Things (IoT) devices, GreenGrid Energy operates at the intersection of Operational Technology (OT) and Information Technology (IT). This convergence necessitates a comprehensive cybersecurity approach, robust governance frameworks, and specialized departmental oversight.

To effectively respond to these challenges, GreenGrid Energy has assembled a dedicated project team to assess and strengthen information security practices within critical departments, while collaboratively addressing overall cybersecurity objectives.

1.1.1 Project Team Structure and Individual Responsibilities

The project team is composed of three specialists, each focusing on securing a critical area of operation:

Research & Development

Inês Ribeiro (1201346@isep.ipp.pt) assesses and enhances security practices within the RD department, safeguarding proprietary technologies, algorithms, and intellectual property. She ensures secure collaborative environments for technology pilot programs, mitigating risks from industrial espionage and cyber threats.

Supply Chain Management

Manuela Leite (1200720@isep.ipp.pt) is responsible for analyzing procurement processes, supplier security standards, and component lifecycle management. Her primary focus includes establishing guidelines to mitigate risks associated with third-party vendors, particularly regarding hardware integrity and supply-chain vulnerabilities.

Engineering & Operations

Eduardo Sousa (1200920@isep.ipp.pt) oversees the security and resilience of critical grid infrastructure, ensuring SCADA systems, OT networks, and renewable energy integrations are safeguarded against cyber threats. His role includes maintaining compliance with industry regulations, implementing advanced monitoring solutions, and coordinating incident response plans to minimize operational disruptions.

1.1.2 Collective Responsibilities

Beyond their individual roles, the team collaborates on key areas that affect multiple departments, including:

- **Engineering & Grid Operations:** Ensuring secure integration of emerging technologies, particularly within OT and IT networks, to maintain operational integrity.
- **Human Resources (HR):** Implementing role-based access control and promoting a security-aware culture through employee training and awareness programs.
- **Legal & Administration:** Aligning departmental activities with legal and regulatory requirements, managing compliance frameworks, and streamlining incident reporting mechanisms.
- **Cybersecurity Strategy Development:** Creating comprehensive security policies, incident response plans, and risk mitigation frameworks applicable organization-wide.

1.1.3 Forward-Looking Objectives

The project team's strategic objectives include:

1. Conducting comprehensive risk assessments to identify critical assets, vulnerabilities, and potential impacts across departments.
2. Implementing an Information Security Management System (ISMS) aligned with recognized international frameworks (such as ISO 27001 or NIST CSF).
3. Ensuring secure convergence and seamless integration between OT and IT infrastructures.
4. Fostering a proactive security culture emphasizing continuous improvement and awareness throughout the organization.

1.2 Governance and Leadership

GreenGrid Energy follows a governance model that balances strategic oversight with efficient operations:

- **Board of Directors:** Define strategic vision, approves major investments, and ensures compliance with energy sector regulations.
- **Chief Executive Officer (CEO):** Oversees day-to-day operations and reports directly to the Board.
- **Executive Management Team:**
 - *Chief Financial Officer (CFO):* Handles budget planning, financial compliance, and resource allocation.
 - *Chief Technology Officer (CTO):* Determines technological direction, including research initiatives and product development.
 - *Chief Operating Officer (COO):* Manages core operations, covering engineering, supply chain, and service delivery.
 - *Chief Information Officer (CIO):* Aligns IT strategy with business objectives and oversees IT infrastructure.
 - *Chief Information Security Officer (CISO):* Develops cybersecurity strategies and enforces best practices across OT and IT domains.
- **Department Directors or Managers:** Lead their respective divisions and report to the relevant C-level executive.

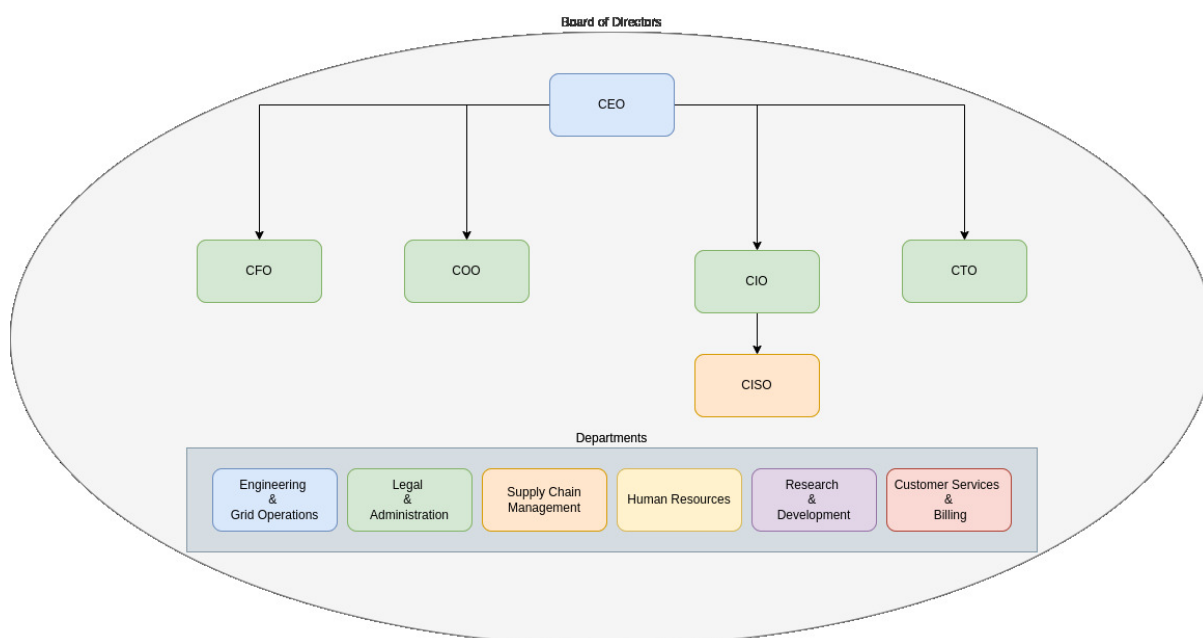


Figure 1.1: Organizational chart of GreenGrid Energy

Figure 1.1 provides an overview of the organization's structure. Each department has a dedicated director, while the executive team members focus on their respective areas of

expertise. Together with the CEO and department directors, these executives form the Board of Directors. All major decisions—including governance matters and the scope of new or revised policies—must be approved by this governing body before implementation throughout the company and its individual departments.

1.3 Key Departments

GreenGrid Energy employs a total of 400 staff members. Of these, 12 serve in leadership roles across the Board of Directors and C-level positions, leaving 388 employees distributed among the following six core departments. Each department is led by a Director or Manager, who reports to the relevant executive.

1.3.1 Engineering & Grid Operations

The Engineering & Grid Operations department at GreenGrid Energy is responsible for designing, maintaining, and optimizing the physical power distribution network. This includes real-time monitoring of energy flow, grid stability, and operational efficiency. The department plays a critical role in integrating renewable energy sources into the smart grid infrastructure while ensuring compliance with regulatory standards.

Core Responsibilities

The department's key responsibilities include:

- **Grid Infrastructure Management:** Overseeing the deployment, maintenance, and upgrades of smart grid components, including substations, transmission lines, and Distributed Energy Resources (DER).
- **Supervisory Control and Data Acquisition (SCADA) System Operations:** Ensuring continuous monitoring and control of grid assets using SCADA systems to maintain grid stability and prevent outages.
- **Grid Security and Reliability:** Implementing resilience measures to protect against cybersecurity threats, natural disasters, and system failures.
- **OT Security:** Managing the convergence of IT and OT environments by deploying security controls for grid-connected devices and industrial control systems.
- **Incident Response and Disaster Recovery:** Developing contingency plans to mitigate risks associated with grid failures, cyberattacks, and supply chain disruptions.
- **Integration of Renewable Energy:** Managing the technical challenges of incorporating solar, wind, and other renewable energy sources into the smart grid.

Infrastructure and Technology Stack

The Engineering & Grid Operations department relies on the following core technologies:

- **SCADA Systems:** Used for real-time monitoring and control of critical grid components.

- **IoT Sensors and Smart Meters:** Providing detailed performance data from field assets to optimize energy distribution.
- **Edge Computing:** Enabling localized data processing for low-latency decision-making.
- **Hybrid Cloud Platforms (AWS/Azure):** Supporting predictive analytics, system automation, and secure data storage.
- **Firewall and Intrusion Detection System (IDS)/Intrusion Prevention System (IPS) Solutions:** Ensuring network security through robust threat detection mechanisms.
- **OT/IT Network Segmentation:** Implementing strict security controls to prevent unauthorized access between corporate IT and operational networks.

Departmental Management Structure

The Engineering & Grid Operations department is led by an **Engineering & Grid Operations Manager**, who reports directly to the COO. The internal structure is organized as follows:

- **Engineering & Grid Operations Manager:** Provides strategic oversight, ensures grid stability, and aligns department objectives with company goals.
- **Grid Infrastructure Lead:** Oversees grid modernization projects, substation maintenance, and infrastructure expansion efforts.
- **SCADA and Control Systems Specialist:** Manages SCADA operations, ensuring continuous monitoring, control, and security of grid systems.
- **OT Security Engineer:** Focuses on securing grid-connected assets and mitigating cyber threats targeting operational technology.
- **Renewable Energy Integration Specialist:** Ensures seamless incorporation of renewable energy sources, optimizing grid balancing and energy distribution.
- **Field Operations Supervisor:** Coordinates on-site maintenance teams, ensuring safety compliance and operational efficiency in power distribution.

1.3.2 Research & Development Department

Focused on innovation and next-generation solutions, the RD department is dedicated to advancing smart grid technology, predictive analytics, and renewable energy systems through proprietary innovations. It ensures secure environments for technology development and rigorously safeguards intellectual property against cybersecurity threats.

Core Responsibilities

The main responsibilities of the department include:

- **Predictive Analytics and Algorithm Development:** Creating advanced algorithms and analytical tools designed to optimize grid performance, improve reliability, and forecast energy demands more accurately.
- **Secure Prototype Development and Testing:** Overseeing the creation and rigorous testing of technological prototypes within secure environments, mitigating cybersecurity risks and ensuring compliance with quality standards before deployment.
- **Intellectual Property Protection:** Implementing strong security controls and procedures to safeguard proprietary technology, research data, and innovations against industrial espionage, unauthorized access, and data leakage.
- **Integration with Engineering & Grid Operations:** Collaborating closely with the Engineering department to facilitate the seamless transition of validated technologies from the development stage to practical, operational environments.

Organizational Structure

The R&D department is managed by the Director of R&D, who reports directly to the Chief Technology Officer (CTO). The department structure includes dedicated specialists in algorithm development, cybersecurity and intellectual property management, prototype testing, and cross-departmental collaboration.

Future Strategic Initiatives

- **Enhanced IP Management and Security:** Strengthening procedures for intellectual property protection, including regular audits and updated cybersecurity practices.
- **Centralized Validation Platform:** Establishing a unified platform for securely validating algorithms and technologies, ensuring high standards of integrity and reliability.
- **Collaborative Innovation Partnerships:** Expanding collaboration with external technology partners and academic institutions, accelerating innovation while securely leveraging shared expertise.

1.3.3 Customer Services & Billing

All client-facing activities—such as account management, billing, and technical support—fall under this department’s purview, serving both residential and enterprise customers. Protecting personal and financial data is paramount, requiring rigorous compliance with data privacy regulations and prompt issue resolution to maintain customer satisfaction.

1.3.4 Supply Chain Management Department

The Supply Chain Management department at GreenGrid Energy plays a crucial role in supporting the company's operational efficiency and strategic goals. Its primary responsibilities include procuring, assessing, and managing the acquisition of hardware, software, and external services necessary for the company's operations. Given the company's strong emphasis on cybersecurity and compliance, this department ensures that all acquired resources and services adhere to rigorous security standards and regulatory requirements.

To address the complexity of procurement and vendor management activities effectively, the Supply Chain Management department is organized with clearly defined roles under the supervision of a Supply Chain Manager, who directly reports to the COO. The internal structure of this department is as follows:

- **Supply Chain Manager:** Responsible for strategic oversight, departmental leadership, and alignment of procurement processes with organizational objectives. Coordinates overall procurement strategies and supervises team performance.
- **Hardware Procurement Specialist:** Oversees the procurement, logistics, inventory management, and verification of all physical hardware components, such as smart-grid devices, sensors, and power management equipment. Ensures hardware security integrity and vendor reliability.
- **Software Procurement Specialist:** Manages the procurement of software assets, licenses, analytics tools, and cybersecurity solutions. Collaborates closely with the CIO and CTO to confirm software solutions align with technology strategies and cybersecurity guidelines.
- **Service Procurement Specialist:** Focuses on acquiring external services critical to operations, such as consulting engagements, technical training programs, support contracts, and maintenance services. Responsible for monitoring the quality and compliance of service providers.
- **Vendor Relationship Specialist:** Dedicated to managing strategic vendor relationships across hardware, software, and services. Conducts vendor risk assessments, security audits, and compliance verifications to mitigate supply chain-related risks.

This structure ensures clear accountability, specialization of roles, and scalability to meet future operational demands. It also aligns closely with GreenGrid Energy's cybersecurity framework by ensuring thorough vetting and continuous monitoring of all vendors and acquired resources.

The organizational hierarchy within the Supply Chain Management department is depicted below:

Through this structured organization, the Supply Chain Management department ensures efficient operations, robust security controls, and strategic alignment with GreenGrid Energy's business objectives.

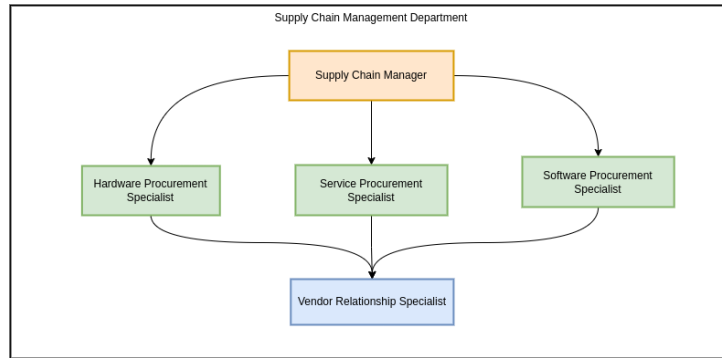


Figure 1.2: Organizational chart of Supply Chain Management Department

1.3.5 Human Resources (HR)

HR oversees recruitment, training, performance evaluation, and overall employee welfare. As part of the company's broader security posture, HR also manages background checks, **RBAC!** (RBAC!), and ongoing security awareness initiatives to ensure that all staff understand and adhere to established security protocols.

1.3.6 Legal & Administration

This department ensures that GreenGrid Energy remains compliant with evolving industry regulations and standards. Core tasks include contract drafting and review, regulatory monitoring, and oversight of administrative budgeting. By maintaining legal and procedural integrity, the Legal & Administration team supports the organization's ability to operate smoothly and avoid compliance risks.

1.4 Infrastructure and Security Context

1.4.1 Core Technologies and Systems

GreenGrid Energy's infrastructure comprises several critical technologies supporting operational excellence, security, and departmental integration.

SCADA Systems These systems allow real-time control and monitoring of grid equipment, essential for the reliability and stability of energy distribution operations.

Hybrid Cloud Platforms (AWS/Azure) Offer scalable computing, secure data storage, advanced analytics, and support for IoT device management, facilitating innovation and departmental collaboration.

Edge Computing Provides local data processing capabilities near physical assets, ensuring low latency and rapid response for critical grid management tasks.

Microsoft 365 The primary platform for internal communication, collaboration, and productivity across all company departments.

SAP Enterprise Resource Planning (ERP) Integrates business-critical functions such as procurement, inventory management, customer services, financial oversight, and regulatory compliance.

1.4.2 Network Topology

GreenGrid Energy maintains two distinct networks to segregate operational and corporate functions securely:

- **OT Network:** Hosts grid-specific operations, including SCADA systems and field-deployed IoT devices.
- **IT Network:** Manages corporate services such as ERP systems, collaboration tools, and HR applications.

Secure segmentation between the OT and IT networks is essential to safeguard critical infrastructure operations.

1.4.3 Threat Landscape

The primary cybersecurity threats facing GreenGrid Energy include:

- **Nation-State Actors:** Target critical infrastructure for strategic objectives and disruption.
- **Advanced Persistent Threats (APTs):** Sophisticated attackers leveraging vulnerabilities in IoT and grid-related technologies.
- **Supply Chain Risks:** Compromise of hardware or software components through third-party suppliers.

1.4.4 Technology and Department Association

The following table associates each core technology with its primary departmental users, highlighting responsibility and ensuring clear governance:

Table 1.1: Core Technologies and Associated Departments

Technology/System	Primary Department(s)
SCADA Systems	Engineering & Grid Operations
Hybrid Cloud Platforms (AWS/Azure)	IT, RD
Edge Computing	Engineering & Grid Operations, RD
Microsoft 365	All Departments
SAP ERP	Supply Chain, Customer Services, Legal & Administration, HR
OT Network	Engineering & Grid Operations
IT Network	IT, Legal & Administration, HR

This clear and organized mapping ensures effective oversight, accountability, and management of cybersecurity risks across the company's operational infrastructure.

Chapter 2

ISMS Scope

Aligned with ISO/IEC 27001 Clause 4.3 guidelines,² this chapter details GreenGrid Energy’s *ISMS* scope by identifying the key stakeholders, describing shared IT infrastructure, highlighting core business processes, and specifying the boundaries within which the ISMS will operate.

2.1 Organizational Stakeholders

GreenGrid Energy’s stakeholders, as defined by ISO/IEC 27001, include both internal and external entities that can influence—or be influenced by—the organization’s security practices.⁴ Table 2.1 summarizes the principal stakeholder groups and their roles in relation to the ISMS.

Table 2.1: Stakeholders and ISMS Interaction

Stakeholder Group	Interaction with the ISMS
Executive Management and Board	Provide strategic oversight, allocate resources, approve ISMS scope, and review security performance.
IT Department	Implement and maintain technical security controls; daily management of the ISMS infrastructure.
Department Heads and Employees	Comply with ISMS policies, handle information securely, report incidents, and participate in risk assessments.
Customers and Clients	Expect protection of data confidentiality, integrity, and availability as part of service agreements.
Suppliers and Third-Party Providers	Comply with contractual security requirements to ensure the security of GreenGrid data processed externally.
Regulators and Authorities	Expect adherence to industry regulations and may audit ISMS practices and compliance.
Certifying Bodies/Auditors	Evaluate and validate compliance with ISO/IEC 27001 through periodic certification audits.

2.2 Shared IT Infrastructure and Systems

GreenGrid Energy employs a centrally managed IT infrastructure used across multiple departments. Key elements of this shared environment include:

- **Network Infrastructure:** Company-wide network including Local Area Network (LAN), secure Wi-Fi, and Virtual Private Network (VPN) for remote employees.
- **Server and Cloud Systems:** Hosting internal applications, databases, and departmental services.
- **Enterprise Applications:** Microsoft 365, SAP ERP, and Customer Relationship Management (CRM) software supporting business operations and collaboration.
- **User Devices:** Managed desktop computers, laptops, and mobile devices.
- **Data Storage and Backup Systems:** Centralized data repositories and backup solutions.
- **Communication and Collaboration Tools:** Email systems, instant messaging platforms, video conferencing, and intranet portals.

Each department relies on these resources for day-to-day operations. Chapter 3 will focus on specific requirements, objectives, and policies around these systems, while this chapter captures their basic description for scope purposes.

2.3 Business Processes, Data, and Security Risks by Department

2.3.1 Engineering & Operations

The Engineering & Operations Department serves as the backbone of GreenGrid Energy's infrastructure, ensuring the seamless integration and reliable performance of smart-grid technologies and renewable energy systems. This department is responsible for designing, deploying, and maintaining critical operational assets, balancing efficiency, scalability, and cybersecurity. The ISMS scope encompasses key operational processes, addressing risks associated with grid stability, system automation, and industrial control systems while aligning with the organization's broader security objectives.

Grid Infrastructure Management:

- **Activities:** Overseeing deployment, maintenance, and modernization of grid components.
- **Data Processed:** Grid topology data, maintenance logs, infrastructure monitoring reports.
- **Cybersecurity Risks:** Unauthorized system modifications, physical and cyber tampering, outdated firmware vulnerabilities.
- **Technologies:** SCADA systems, asset management platforms, industrial-grade firewalls.

SCADA System Operations:

- **Activities:** Monitoring and controlling grid assets for stability and reliability.
- **Data Processed:** Real-time grid performance data, event logs, control commands.
- **Cybersecurity Risks:** Remote access exploitation, SCADA malware, data interception.
- **Technologies:** Secure remote access solutions, IDS, encrypted communication channels.

Incident Response and Disaster Recovery:

- **Activities:** Developing and executing contingency plans for cyber and operational incidents.
- **Data Processed:** Incident reports, forensic data, response logs.
- **Cybersecurity Risks:** Prolonged downtime, inadequate threat response, lack of forensic integrity.
- **Technologies:** Automated threat detection, backup and recovery solutions, Security Information and Event Management (SIEM) platforms.

Renewable Energy Integration:

- **Activities:** Managing the integration of solar, wind, and other renewable energy sources.
- **Data Processed:** Renewable generation data, demand-response metrics, battery storage status.
- **Cybersecurity Risks:** Grid imbalances, data manipulation, unauthorized control access.
- **Technologies:** Smart inverters, edge computing for energy optimization, blockchain for energy transactions.

2.3.2 Research & Development (R&D)

The RD Department plays a strategic role at GreenGrid Energy, providing innovative solutions essential for enhancing smart-grid operations and renewable energy technologies. The ISMS scope outlines the department's core processes, explicitly highlighting the data handled, relevant cybersecurity risks, and utilized technologies, aligning with the ISMS objectives.

Proprietary Research and Innovation Process

This process involves identifying, researching, and evaluating emerging technologies and concepts that can potentially enhance grid efficiency and reliability.

Activities:

- Market and technology research
- Feasibility analysis and experimentation
- Preliminary risk assessment of potential innovations

Data Processed:

- Market intelligence data
- Experimental research results

Cybersecurity Risks:

- Data leakage of research findings
- Unauthorized access to research environments

Technologies:

- Cloud platforms
- Research databases and analytics tools

Algorithm and Software Development

This process is dedicated to the systematic creation and validation of predictive analytics algorithms and software for operational use in grid optimization and energy distribution forecasting.

Activities:

- Specification of requirements
- Software coding and iterative development cycles
- Simulation-based testing and validation
- Continuous security assessments during development

Data Handled:

- Proprietary algorithmic code
- Simulated and historical grid data

Security Risks:

- Intellectual property theft
- Vulnerabilities in software code

Technologies:

- Advanced simulation tools
- Code repositories and CI/CD pipelines

Prototype Development and Testing

Prototypes of innovative solutions are built and securely tested to verify their effectiveness, reliability, and resilience to cyber threats.

Activities:

- Development of technology prototypes
- Secure environment configuration for testing
- Conducting controlled cybersecurity assessments
- Documentation and analysis of testing outcomes

Data Handled:

- Prototype technical specifications
- Test results and security assessments

Security Risks:

- Leakage of sensitive design specifications
- Unauthorized access during testing phases

Technologies Used:

- Testing and simulation environments
- Computing infrastructures

Intellectual Property Protection

Ensuring strong protection of intellectual property is essential for maintaining the competitive edge and minimizing risks of industrial espionage and data breaches.

Activities:

- Documentation and protection of R&D outputs
- Management of patent filing processes
- Regular security audits for IP management

Data Handled:

- Intellectual property records and documentation
- Sensitive research outcomes

Security Risks:

- Industrial espionage attempts
- Intellectual property data breaches

Technologies Used:

- Secure data storage solutions
- Encryption and secure communication tools

Technology Integration and Collaboration

This process focuses on transitioning validated technologies from the R&D department into operational use, working closely with Engineering & Grid Operations.

Activities:

- Collaborative planning and joint validation sessions
- Cross-departmental training and knowledge transfer
- Monitoring and support during initial deployment phases

Data Handled:

- Integration plans and documentation
- Performance and reliability data from integration tests

Security Risks:

- Integration-related vulnerabilities
- Compromise during the operational handover process

Technologies Used:

- Collaboration platforms (Microsoft 365, Jira)
- Secure configuration management systems

2.3.3 Customer Services

Key Processes and Data:

Client contracts, billing data, CRM, customer Personally Identifiable Information (PII)

Security Risks:

Privacy breaches, financial fraud, unauthorized data disclosure

2.3.4 Finance

Key Processes and Data:

Financial management (budgeting, transactions, payroll, ERP financial module)

Security Risks:

Financial fraud, phishing attacks, unauthorized access, data tampering

2.3.5 Supply Chain Management

Procurement and Sourcing

Oversees the end-to-end procurement lifecycle for hardware, software, and services by:

- Drafting Requests For Proposals (RFPs) or Requests For Quotes (RFQs).
- Conducting vendor evaluations and security due diligence.
- Negotiating contracts and maintaining supplier agreements.

Associated data supporting this process:

- Vendor profiles and security certifications.
- Product specifications (e.g., smart grid components, software licenses).
- Pricing details, purchase orders, and invoices.

Vendor Relationship Management

Manages ongoing relationships with approved suppliers to ensure adherence to GreenGrid Energy's security and performance standards by:

- Monitoring Service-Level Agreement (SLA) requirements.
- Tracking vendor performance and compliance metrics.
- Conducting periodic vendor risk assessments, especially for critical components.

Relevant data for this process:

- Contract terms and SLA metrics.
- Vendor incident reports or audit findings.
- Communication records (emails, project updates, meeting minutes).

Inventory & Logistics Coordination

Coordinates warehousing, transportation logistics, and inventory control once goods or services are procured by:

- Tracking shipment and delivery status of hardware components.
- Verifying integrity and authenticity of infrastructure parts.
- Overseeing storage, handling, and distribution to operational sites.

Data types maintained in this process:

- Shipping documentation (e.g., bills of lading, customs paperwork).
- Inventory levels and restocking details.
- Asset tracking logs (equipment serial numbers, batch numbers).

Compliance and Risk Management

Ensures that supplier relationships and procurement activities meet security policies and relevant regulations by:

- Reviewing supplier security audits and certifications.
- Ensuring compliance with data protection and trade regulations.
- Coordinating corrective actions for supplier or logistics risks.

Data associated with this process:

- Audit reports, compliance checklists, and regulatory filings.
- Documentation of risk treatment actions (vendor replacements, contract updates).
- Internal approval records and compliance sign-offs.

Contract and SLA Oversight

Manages contractual obligations from initial sign-off to renewal or termination by:

- Monitoring contract milestones (renewal dates, penalty clauses).
- Ensuring suppliers meet service quality and security requirements.
- Handling contract amendments for security or operational changes.

Key data involved:

- Master Service Agreements (MSAs), Statements Of Work (SOWs).
- Change requests and contract amendment records.
- Legal correspondence regarding contract disputes or terminations.

2.3.6 Human Resources

Key Processes and Data:

Employee management (personal records, payroll data, performance data)

Security Risks:

Unauthorized disclosure, insider threats, privacy breaches

2.3.7 IT Department

Key Processes and Data:

Infrastructure management (network devices, servers, endpoint devices, IAM systems, incident response data)

Security Risks:

System compromise, configuration errors, misuse of admin privileges

2.3.8 Sales and Marketing

Key Processes and Data:

Customer relationship management (CRM), market data, public-facing web resources

Security Risks:

Unauthorized access, reputation damage, phishing/malware attacks

2.4 ISMS Boundaries and Exclusions

The ISMS boundaries include:

- Internal IT and OT networks, including SCADA and enterprise systems used by the Supply Chain Management, Customer Services & Billing, and Research & Development departments.
- Data processing within cloud environments generated or consumed by Supply Chain Management, Customer Services & Billing, and Research & Development.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Explicit exclusions from the ISMS scope include:

- Third-party systems fully managed externally, where GreenGrid has no direct control.
- Personal employee devices not centrally managed by the organization.
- Physical security at externally managed premises (e.g., leased data centers).
- Separate subsidiaries or partner organizations outside direct oversight.

These exclusions are justified by the lack of direct administrative oversight or practical manageability; any associated risks are mitigated through contractual obligations and vendor assessments.¹

Chapter 3

Information Security Policy and Objectives

This chapter addresses the next phase of establishing GreenGrid Energy’s ISMS by incorporating stakeholder requirements, business goals, security objectives, leadership commitment, and overall compliance needs.

3.1 Stakeholder Requirements and Business Goals

As established in Chapter 2, GreenGrid Energy’s stakeholders include Executive Management, the IT Department, Department Heads & Employees, Suppliers, Clients, Regulators, and Certifying Bodies. Because the ISMS scope specifically includes:

- Internal IT and OT networks, including SCADA and enterprise systems used by **Supply Chain Management, Customer Services & Billing**, and **RD** departments.
- Data processing within cloud environments generated or consumed by **Supply Chain Management, Customer Services & Billing**, and **RD**.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Most stakeholder requirements focus on ensuring robust controls to protect:

- Critical infrastructure.
- Sensitive customer and financial data.
- Intellectual property from RD activities.
- Secure procurement of hardware/software through the Supply Chain Management department.
- Proper handling of employee data and permissions.

In contrast, stakeholders agree that **third-party systems fully managed externally, personal employee devices, physical security at externally managed premises, and separate subsidiaries or partner organizations outside direct oversight** are explicitly out of scope, thus reducing direct stakeholder interest in those areas.

3.2 Leadership Commitment

GreenGrid Energy's board of directors reinforce the ISMS by:

- **Allocating Sufficient Budgets:** Funding security tools and training for departments within the ISMS boundaries.
- **Championing Policy Adoption:** Ensuring all employees and department heads integrate the new Information Security Policy into their daily operations.
- **Encouraging a Security Culture:** Mandating ongoing training on secure processes, especially for staff involved in vendor management and grid operations.
- **Reviewing ISMS Performance:** Conducting periodic management reviews to track key risk metrics, incident reports, and audit findings.

3.3 Monitoring and Review of ISMS Performance

To ensure continuous improvement, GreenGrid Energy will measure and review ISMS effectiveness through:

- **Annual ISMS Audit:** Conduct full audits and ensure corrective actions for non-conformities.
- **Key Risk Indicators (KRIs):** Monitor unauthorized access attempts, security incidents, and policy violations.
- **Management Review Meetings:** Perform biannual ISMS performance reviews with Executive Management.

3.4 Risk Management Goals and Compliance Requirements

Given the potential threats to the included systems and data, the organization sets forth the following overarching risk management goals:

- **Protect OT and IT Convergence:** Keep SCADA, IoT, and enterprise networks resilient against cyber threats.
- **Safeguard Data Privacy and Integrity:** Ensure confidentiality of customer billing data, vendor records, and intellectual property from RD.
- **Maintain Regulatory Compliance:** Satisfy relevant European Union (EU) directives such as NIS 2, and meet ISO/IEC 27001 standards to secure continuous certification and avoid penalties.
- **Mitigate Vendor and Procurement Risks:** Enforce security checks during procurement of critical hardware/software, and conduct regular vendor risk assessments.
- **Enhance Incident Response Preparedness:** Develop rapid containment strategies for security breaches or supply chain disruptions, minimizing downtime of grid operations.

3.5 Information Security Policy (Clause 4.2)

Policy Statement

GreenGrid Energy is committed to safeguarding the confidentiality, integrity, and availability of information assets within the boundaries of its ISMS, specifically covering:

- Internal IT and OT networks that power core operations.
- Data processed through corporate cloud environments.
- Procurement and vendor relationships supporting operational continuity.
- Employee access management, training, and HR-related records.

Key Principles

- **Risk-Based Controls:** Security measures must be tailored to identified threats, focusing on high-risk areas such as SCADA, third-party supplier links, and RD data.
- **Legal and Regulatory Compliance:** Adhere to ISO/IEC 27001, NIS 2, and national data protection laws relevant to energy operations.
- **Continuous Improvement:** Policies, controls, and training programs will be reviewed at least annually or following major incidents.

Responsibilities

- **CISO:** Oversees policy implementation and audits across IT, OT, and supply chain operations.
- **Department Directors:** Ensure departmental processes adhere to this policy; sponsor secure practices among staff.
- **All Employees:** Follow approved procedures, maintain vigilance for potential threats, and report incidents promptly.

3.6 Department-Specific Security Objectives (Clause 6.2)

Below are the measurable information security objectives for each major department within the ISMS scope. Each subsection also highlights the primary stakeholders driving or benefiting from these goals.

3.6.1 Engineering & Operations

Stakeholders:

- **Grid Operations Teams:** Manage real-time grid stability and control systems.
- **SCADA and Industrial Control Engineers:** Maintain secure and reliable SCADA environments.

- **Regulatory Authorities:** Oversee compliance with national and EU grid security regulations.
- **IT Security and Network Teams:** Secure OT/IT convergence to protect grid operations.

Objectives:

- **Objective EO-1: Strengthen SCADA System Security**
 - **Target:** Ensure 100% of SCADA systems have up-to-date security patches and network segmentation controls.
 - **Measure:** Compliance rate of SCADA system updates and segmentation audits.
 - **Owner:** SCADA Security Team, CISO.
- **Objective EO-2: Improve OT Network Visibility and Anomaly Detection**
 - **Target:** Deploy real-time monitoring tools to achieve a 90% anomaly detection rate in OT networks.
 - **Measure:** Number of security alerts detected vs. actual threats mitigated.
 - **Owner:** Engineering Security Lead, IT Security Team.
- **Objective EO-3: Enhance Physical and Cyber Resilience of Grid Infrastructure**
 - **Target:** Perform biannual security assessments for grid substations and power distribution control centers.
 - **Measure:** Number of identified vulnerabilities mitigated before next assessment cycle.
 - **Owner:** Grid Operations Manager, CISO.

3.6.2 Supply Chain Management

Stakeholders:

- **Supply Chain Staff:** Procurement Specialists, Vendor Relationship Managers.
- **Vendors and Third Parties:** Must comply with security checks, audits, and contract clauses.
- **Executive Management:** Requires assurance of uninterrupted, secure component supply.

Objectives:

- **Objective SC-1: Reduce High-Risk Vendor Gaps**
 - **Target:** Conduct security audits for 100% of critical suppliers (hardware/software) each year.
 - **Measure:** Percentage of critical vendors audited; number of unaddressed security findings.
 - **Owner:** Supply Chain Manager, CISO.
- **Objective SC-2: Strengthen Procurement Integrity**
 - **Target:** Implement additional due diligence (e.g., secure code validation, hardware authenticity checks) in 80% of high-value procurements.
 - **Measure:** Number of purchases with documented security screening vs. total high-value procurements.
 - **Owner:** Supply Chain Manager, IT Department.

3.6.3 Customer Services & Billing

Stakeholders:

- **Customer Services Staff:** Manage billing, handle customer inquiries and personal data.
- **Clients:** Expect confidentiality of financial and personal information.
- **Regulators (e.g., Data Protection Authorities):** Enforce compliance with privacy regulations.

Objectives:

- **Objective CS-1: Enhance Data Privacy Controls**
 - **Target:** Achieve zero high-severity data breaches in billing systems each quarter.
 - **Measure:** Number of verified privacy incidents rated high severity.
 - **Owner:** Customer Services Director, CISO.
- **Objective CS-2: Improve Customer Incident Handling**
 - **Target:** Reduce average incident resolution time by 25% over 12 months for billing-related security issues.
 - **Measure:** Mean Time to Resolve (MTTR) for billing-system incidents.
 - **Owner:** Customer Services Director, IT Department.

3.6.4 Research & Development (RD)

Stakeholders:

- **RD Teams:** Create proprietary analytics algorithms and software for grid optimization.
- **Executive Management:** Relies on RD innovation for market competitiveness.
- **Intellectual Property Owners:** Concerned about protecting patents, code repositories, trade secrets.

Objectives:

- **Objective RD-1: Protect Proprietary Code and IP**
 - **Target:** Perform secure code reviews for all major RD releases, reaching 90% coverage of new commits.
 - **Measure:** Percentage of RD code commits subjected to security scanning or manual review.
 - **Owner:** RD Manager, CISO.
- **Objective RD-2: Prevent Unauthorized Access to RD Data**
 - **Target:** Achieve a 50% reduction in unauthorized access attempts or security alerts within the RD environment (cloud or on-prem).
 - **Measure:** Number of RD-specific security alerts vs. the prior reporting period.
 - **Owner:** RD Manager, IT Department.
- **Objective RD-3: Strengthen Security of Innovation Environments**
 - **Target:** Perform quarterly audits of RD environments to identify and mitigate vulnerabilities.
 - **Measure:** Audit completion rate and resolution of identified vulnerabilities.
 - **Owner:** Director of RD IT Security Team.

Chapter 4

Other Policies and Procedures

4.1 Other Security Policies

Beyond the central Information Security Policy (Clause 4.2), additional organization-wide security policies are essential to address specific operational contexts within GreenGrid Energy. The following policy is explicitly designed to support the secure execution of research activities and protection of critical intellectual property:

4.1.1 RD Intellectual Property and Data Security Policy

Purpose: To ensure comprehensive protection of GreenGrid Energy’s proprietary algorithms, innovations, and research data against unauthorized access, disclosure, modification, or destruction.

Policy Statements:

- **Data Classification and Handling:** All RD-generated data and proprietary code must be classified as Confidential or Highly Confidential. Access to such data shall follow a strict need-to-know basis, utilizing role-based access control (RBAC).
- **Encryption:** All RD data stored at rest or transmitted over networks (both internal and external) must be encrypted using approved encryption standards and technologies.
- **Secure Development and Testing Environment:** Prototype development and testing environments must adhere to strict isolation protocols, ensuring restricted access, proper authentication, regular vulnerability scanning, and thorough security audits.
- **Vendor and Partner Compliance:** All third-party technology partners and academic institutions involved in RD activities must comply with GreenGrid’s security requirements, undergo periodic security assessments, and sign confidentiality agreements.
- **Incident Reporting and Response:** All suspected security incidents within the RD context, including potential data leaks or unauthorized access attempts, must be reported immediately according to the defined incident management procedure.

Roles and Responsibilities:

- **RD Director:** Oversees policy compliance within RD.
- **CISO:** Provides oversight, conducts audits, and ensures enforcement of compliance measures.
- **All RD Employees:** Adhere strictly to this policy and report breaches or concerns promptly.

4.1.2 Operational Technology (OT) & Infrastructure Security Policy

Purpose:

To ensure the security, availability, and integrity of GreenGrid Energy's OT, critical infrastructure, and cloud-based engineering systems by defining security controls for network segmentation, access control, monitoring, and incident response.

Policy Statements:

- Network Segmentation and Access Control:
 - Separation of IT and OT networks must be enforced using firewalls, VLANs, and zero-trust architectures.
 - Remote access to SCADA/Incident Command System (ICS) environments must be restricted to dedicated VPN and jump servers with Multi-factor Authentication (MFA).
- System Hardening and Secure Configuration:
 - All OT and cloud systems must adhere to Center for Internet Security (CIS) benchmarks and secure baseline configurations.
 - Security patches and firmware updates must be applied within 30 days of release, except in cases requiring operational testing.
- Monitoring and Security Auditing:
 - IDS/IPS must monitor OT and cloud networks for unauthorized activity.
 - Security logs from all critical infrastructure systems must be stored for at least 12 months and analyzed periodically.
- Incident Handling and Recovery:
 - All security incidents affecting OT, cloud, and engineering infrastructure must be reported within 15 minutes to the Security Operations Center (SOC).
 - Emergency isolation procedures must be in place to contain cyber threats targeting ICS, SCADA, or cloud resources.

Roles and Responsibilities:

- **Director of Engineering & Operations:** Ensures compliance with OT security policies across all facilities.

- CISO & IT Security Team: Conducts audits, monitors threats, and enforces network security measures.
- OT Administrators & Cloud Engineers: Implement secure configurations, manage access control, and respond to incidents.

4.2 Other Security Procedures

Specific procedures established to implement these policies effectively include:

4.2.1 Procedure 1: Secure Code Review

- **Objective:** Identify and mitigate vulnerabilities in software and algorithm code prior to deployment or release.
- **Steps:**
 1. Schedule code reviews for every major release and document findings.
 2. Utilize static and dynamic analysis tools to automate vulnerability identification.
 3. Perform manual code reviews for critical software components.
 4. Track and manage identified vulnerabilities until resolved.
- **Responsibility:** RD Development Team, supervised by RD Manager and IT Security Team.

4.2.2 Procedure 2: Access Management for R&D Systems

- **Objective:** Control and monitor access to sensitive RD environments and data.
- **Steps:**
 1. Implement Role-Based Access Control (RBAC) to manage employee permissions.
 2. Conduct quarterly audits of access permissions to RD environments and adjust permissions as necessary.
 3. Enforce multi-factor authentication (MFA) for remote access to sensitive environments.
 4. Document all access changes and ensure traceability.
- **Responsibility:** RD Manager, IT Administration Team.

4.2.3 Procedure 3: Incident Management within R&D

- **Objective:** Effectively respond to security incidents affecting the RD environment.
- **Steps:**

1. Report any security incident immediately to the IT Security Operations Center (SOC).
2. SOC evaluates incident severity and initiates appropriate response actions.
3. Contain and remediate the incident promptly, documenting all response activities.
4. Conduct post-incident reviews to identify improvements.

- **Responsibility:** RD Employees, SOC Team, IT Security Team.

4.2.4 Procedure 4: Vendor and Partner Security Assessment

- **Objective:** Ensure that all RD vendors and partners comply with GreenGrid's security standards.

- **Steps:**

1. Perform initial and periodic security risk assessments of vendors and partners.
2. Require evidence of compliance with relevant security certifications (ISO/IEC 27001, SOC 2, etc.).
3. Maintain up-to-date security agreements with clear terms regarding confidentiality and data protection.
4. Review and update vendor and partner risk profiles annually or following significant changes.

- **Responsibility:** Vendor Relationship Specialist, RD Director, IT Security Team.

4.2.5 Procedure 5: Incident Management within OT & Cloud Systems

Objective: Ensure a structured response to security incidents affecting SCADA, ICS, cloud, and engineering infrastructure.

Steps:

- **Detection & Reporting:**

1. All security alerts from IDS/IPS or SIEM must be immediately investigated.
2. OT personnel must report any unusual system behavior to the SOC within 15 minutes.

- **Containment:**

1. Immediately disconnect affected OT systems from external networks.
2. Limit access to critical cloud environments until the incident is fully assessed.

- **Investigation & Root Cause Analysis:**

1. Review SCADA & OT system logs for anomalous activity.
2. Conduct forensic analysis to identify the attack vector.

- **Recovery & Post-Incident Review:**

1. Restore systems from verified secure backups.
2. Implement lessons learned into security policies to prevent future incidents.

Responsibility:

- **SOC Team:** Manages incident response and forensic investigation.
- **OT & Cloud Security Engineers:** Apply security patches and restore affected infrastructure.
- **CISO & Engineering Leadership:** Review security incidents and enforce corrective actions.

Bibliography

- [1] Advisera. All you need to know about setting the iso 27001 scope. <https://advisera.com/27001academy/knowledgebase/how-to-define-the-isms-scope/>, 2023. Accessed: 2024-03-10.
- [2] ISO/IEC. Iso/iec 27001:2022 - information security management systems. <https://www.iso.org/standard/54534.html>, 2022. Accessed: 2024-03-10.
- [3] Portugal 2020. Portugal 2020 – European Structural and Investment Funds, 2020. Accessed: 2025-03-07.
- [4] High Table. Iso 27001 scope statement beginner’s guide. <https://hightable.io/iso-27001-scope-statement/>, 2023. Accessed: 2024-03-10.